

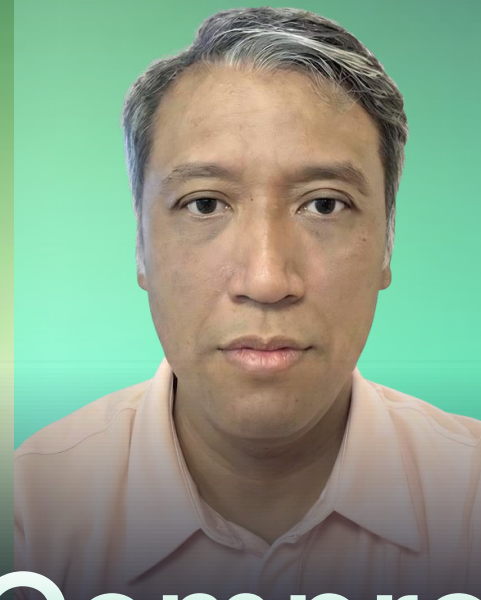
**Miftahudin Luthfi, S.T.,
ECSA**

Cyber Security Expert
PT Noosc Security
Global



**Yohanes Nugroho,
M.Sc., OSCE3**

Senior Security
Researcher PT Xynexis
International



**Santun Gunadi, S.H.,
LL.M (CIPM)**

Data Protection
Consultant
PT Xynexis International



Axios Compromised: Membedah Supply Chain Attack pada Axios

29 April 2026

13.30 - 15.00 WIB

Location

Virtual Zoom Meeting

WEBINAR SERIES

BY **xynexis**

Axios Supply Chain Attack (April 2026)

**Analysis &
Mitigasi**



AGENDA

01

**Ringkasan
insiden**

02

**Anatomi
serangan**

03

**Teknik anti-
forensik**

04

IOC & deteksi

05

**Mitigasi & best
practices**

01 RINGKASAN INSIDEN

- 01 Target: Ekosistem npm (Axios)
- 02 Jenis: Supply Chain Attack
- 03 Dampak: Remote code execution melalui dependency
- 04 Sumber analisis: Huntress, Google Threat Intelligence, Socket



02 ANATOMI SERANGAN (1)

- 01 Aktor: UNC1069 (diduga terkait Korea Utara)
- 02 Teknik utama: Social Engineering
- 03 Target: Maintainer (jasonsaaayman)
- 04 Media: Slack workspace palsu

03 ANATOMI SERANGAN (2)

- 01 Tidak membobol GitHub
- 02 Menggunakan long-lived npm token
- 03 Publish via CLI langsung
- 04 Bypass OIDC (OpenID Connect) Trusted Publisher

04 PHANTOM DEPENDENCY

Malware Tersembunyi

Malware tidak ada di Axios langsung. Disisipkan sebagai dependency: plain-crypto-js@4.2.1

Dampak Penyebaran

Semua project yang install Axios ikut terinfeksi secara otomatis melalui dependency resolution.



CARA KERJA SERANGAN



▶ **STEP 1**

Developer install Axios

▶ **STEP 2**

Npm resolve dependency

▶ **STEP 3**

Plain-crypto-js ikut terinstall

▶ **STEP 4**

Script jahat dijalankan saat install

06 ANTI-FORENSIK (1)

File Swap Technique

Package.json berbahaya dihapus, diganti dengan package.md, kemudian di-rename kembali menjadi package.json

Dampak

Menyulitkan analisis setelah install karena file asli sudah tidak ada.



07

ANTI-FORENSIK (2)



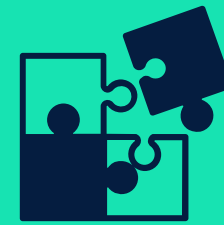
Memory-only execution (Windows). Payload: wt.exe. Tidak meninggalkan file permanen. Menghindari antivirus tradisional.

08 NETWORK IOC



DOMAIN

sfrclak.com:8000



IP ADDRESS

142.11.206.73

09

ARTIFACTS (PER OS)



WINDOWS

%PROGRAMDATA%\wt.exe dan Registry: HKCU\...\Run
(MicrosoftUpdate)



MACOS

/Library/Caches/com.apple.act.mond



LINUX

/tmp/lid.py

10



DEPENDENCY CHECK

Jalankan: `npm ls plain-crypto-js`. Jika muncul, sistem sudah menjalankan malware.

11

DAMPAK NYATA

01

Remote code execution

02

Data exfiltration

03

Persistence via registry / cron

04

Supply chain contamination



12

THE 3-DAY RULE



Gunakan: `npm config set min-release-age 3`. Blok package yang baru rilis kurang dari 3 hari.

13



MITIGASI TAMBAHAN

CI/CD Hardening: `npm install --ignore-scripts`. Mencegah eksekusi script berbahaya saat instalasi.

ALTERNATIF PACKAGE MANAGER

Tidak auto-run postinstall, mencegah serangan supply chain otomatis.



PNPM

Tidak auto-run postinstall scripts, memberikan keamanan lebih baik secara default.



BUN

Tidak auto-run postinstall scripts, alternatif modern yang lebih aman.

15

BEST PRACTICES

01

Rotasi token npm secara rutin

02

Gunakan OIDC Trusted Publisher

03

Audit dependency secara berkala

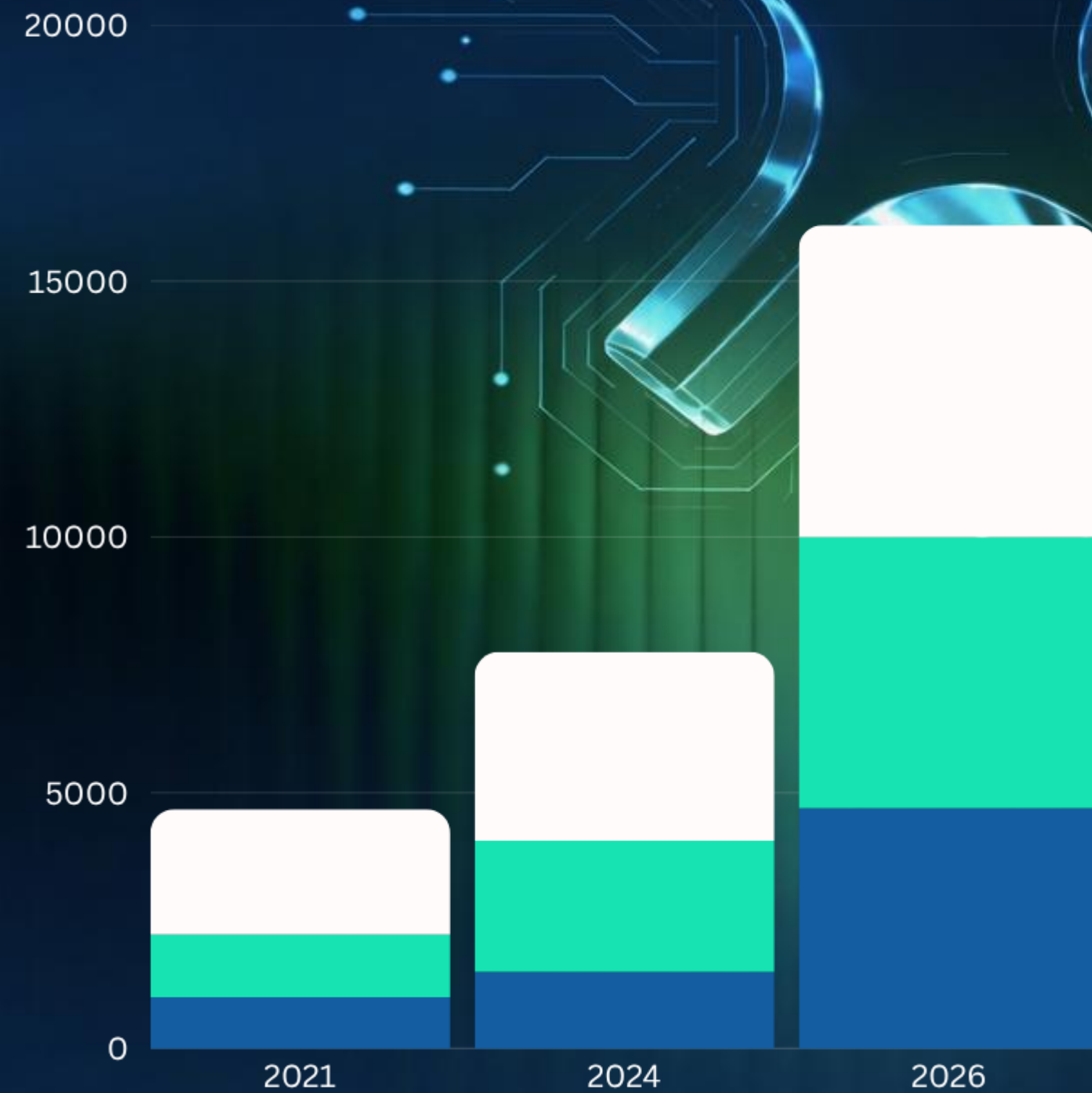
04

Monitor network outbound

16

ANALOGI

- Bayangkan restoran populer. Hacker tidak meracuni makanan, tapi meracuni pemasok garam. Semua masakan jadi berbahaya, meskipun chef tidak mengubah resep.
- Supply chain attack bekerja dengan prinsip yang sama: menyerang sumber, bukan target akhir.



17

KESIMPULAN

01

Serangan sangat terencana

02

Fokus pada manusia + supply chain

03

Dependency adalah titik lemah utama

04

Mitigasi harus berlapis



WEBINAR SERIES

BY **xynexis**

***Security Management, Regulasi UU PDP
& Managed Security Services***



OVERVIEW

Regulasi UU PDP

Sanksi &
kewajiban
pelaporan data
breach

01

Supply Chain Attack

Tren ancaman &
kegagalan
keamanan pasif

02

SMSS Framework

Dari reaktif ke
solusi struktural

03

NOOSC & 24/7

Monitoring &
perluasan tim
keamanan

04

Cost vs Risk

MSS sebagai risk
transfer, bukan
cost center

05

01 REGULASI UU PDP

Undang-Undang Pelindungan Data Pribadi menetapkan kewajiban ketat bagi pengendali data. Pelanggaran berkonsekuensi finansial dan struktural yang signifikan.



Notifikasi KOMDIGI 14 Hari

Batas waktu notifikasi setelah terjadinya data breach
— Permen Kominfo No. 20 Tahun 2016
*3 x 24 jam ke badan PDP



Denda 2% Omzet/Tahun

Sanksi administratif maksimal 2% dari pendapatan tahunan — potensi kerugian masif



BSSN — Infrastruktur Tugas

BSSN bertanggung jawab pada level infrastruktur tugas, menjadi otoritas pengawas keamanan siber nasional

14

HARI

Batas Notifikasi



Omzet / Tahun

Maks. Denda

*3 x 24 jam ke badan PDP

02 SUPPLY CHAIN ATTACK **MENINGKAT**

Dalam tiga tahun terakhir, serangan rantai pasokan meningkat drastis. Keamanan yang hanya bersifat pasif dan reaktif tidak lagi memadai.

Axios

Hanya berulang, dan menjadi pengingat

Bukan kasus pertama dan bukan yang terakhir, menarget supply chain

Pendekatan Reaktif

- × Menunggu insiden terjadi dulu
- × Fokus pada perimeter saja
- × Response time lambat
- × Tidak memverifikasi vendor

Pendekatan Proaktif

- ✓ Deteksi dini & continuous monitoring
- ✓ Zero Trust Architecture
- ✓ Vendor risk assessment berkala
- ✓ 24/7 SOC & incident response

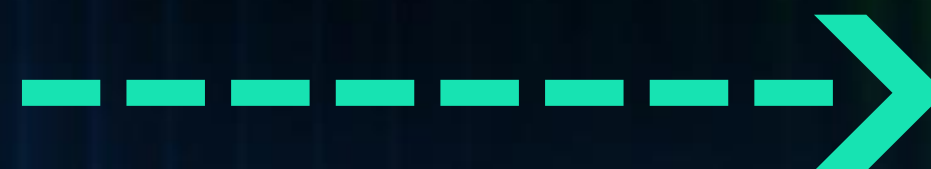
03 MSS FRAMEWORK

Managed Security Services bukan sekadar outsource – ini adalah kerangka kerja struktural yang mengubah paradigma keamanan organisasi Anda.

Pendekatan Lama

"Bagaimana cara menangani insiden?"

Reaktif · Ad-hoc · Fragmented



Pendekatan MSS

"Bagaimana cara mencegah insiden?"

Proaktif · Terstruktur · Terintegrasi

Visibility

Pemantauan menyeluruh seluruh aset & aktivitas

Intelligence

Threat intel & analisis prediktif berkelanjutan

Response

Incident response terstandarisasi & terukur

Improvement

Continuous improvement berdasarkan lesson learned

04 NOOSC & LAYANAN 24/7

MSS bukan sekadar vendor — ini adalah perluasan tim keamanan Anda dengan monitoring berjalan tanpa henti.

Kapabilitas NOOSC

24/7 Real-time Monitoring

Pantau seluruh aset TI tanpa jeda — deteksi anomali dalam hitungan menit

SIEM & Log Correlation

Korelasi log dari berbagai sumber untuk deteksi ancaman tersamar

Threat Hunting Aktif

Proses mencari ancaman yang belum terdeteksi oleh tools otomatis

Incident Triage & Escalation

Klasifikasi & eskalasi insiden sesuai SLA yang disepakati

 Kesalahpahaman

"MSS = Outsourcing keamanan vendor pihak ketiga"

 Realitas

"MSS = Perluasan tim keamanan internal Anda"

Model Kolaborasi

Internal IT + MSS Team = Unified

Security

Shared context, shared responsibility — bukan vendor-klien tradisional

05 MSS: **RISK TRANSFER**, BUKAN COST CENTER

Biaya MSS sering dilihat sebagai pengeluaran. Namun dibandingkan biaya satu insiden, MSS adalah investasi perlindungan yang jauh lebih efisien.

Biaya MSS / Tahun

Terproyeksi

Predictable · Recurring · Budgetable

- ✓ Terencana & bisa dianggarkan
- ✓ Mendukung kepatuhan UU PDP
- ✓ Mengurangi risiko insiden besar

Biaya 1 Insiden

Mendadak

Unpredictable · Catastrophic · Reputational

- × Tidak terduga & sulit dianggarkan
- × Potensi denda UU PDP (2% omzet)
- × Kerugian reputasi & kepercayaan

"MSS bukan **cost center**, tapi **risk transfer**"